PRE-ENTREGA 07

Plan de monitoreo y auditoría AWS

CloudWatch | CloudTrail | AWS Config

EduTrack · Plataforma educativa

Monitoreo de infraestructura, alarmas preventivas, costos y trazabilidad de cambios.

ARQUITECTURA DE REFERENCIA

VPC 10.0.0.0/16 en us-east-1 · dos zonas de disponibilidad · subredes públicas y privadas · un NAT Gateway por zona · Application Load Balancer y servidores EC2 de aplicación · Amazon RDS MySQL Multi-AZ en subred privada · Amazon S3 privado distribuido mediante CloudFront con AWS WAF · Route 53.

María Victoria Strazzolini

Proyecto final · EduTrack

01

ALCANCE Y RECURSOS

Qué vamos a monitorear

El plan se adapta a EduTrack, una plataforma educativa que administra alumnos, cursos, inscripciones y seguimiento del progreso académico. El objetivo es detectar problemas de disponibilidad, rendimiento, conectividad, almacenamiento y costos **antes de que afecten** el acceso o el seguimiento de los cursos.

Arquitectura considerada: VPC 10.0.0.0/16 en us-east-1, distribuida en dos zonas de disponibilidad (us-east-1a y us-east-1b), con una subnet pública y una privada por AZ. El usuario llega por Route 53 (alias) a CloudFront, protegido con AWS WAF. Los contenidos estáticos se sirven desde un bucket de Amazon S3 privado mediante OAC; las solicitudes de la aplicación ingresan a la VPC por HTTPS 443 a través del Internet Gateway hasta el Application Load Balancer, que las reparte a los servidores EC2 de aplicación (HTTP 8080). La aplicación consulta a RDS MySQL Multi-AZ, en subred privada, mediante un endpoint DNS estable (TLS / TCP 3306), con replicación síncrona hacia la instancia standby. Cada AZ tiene su propio NAT Gateway para la salida a Internet.

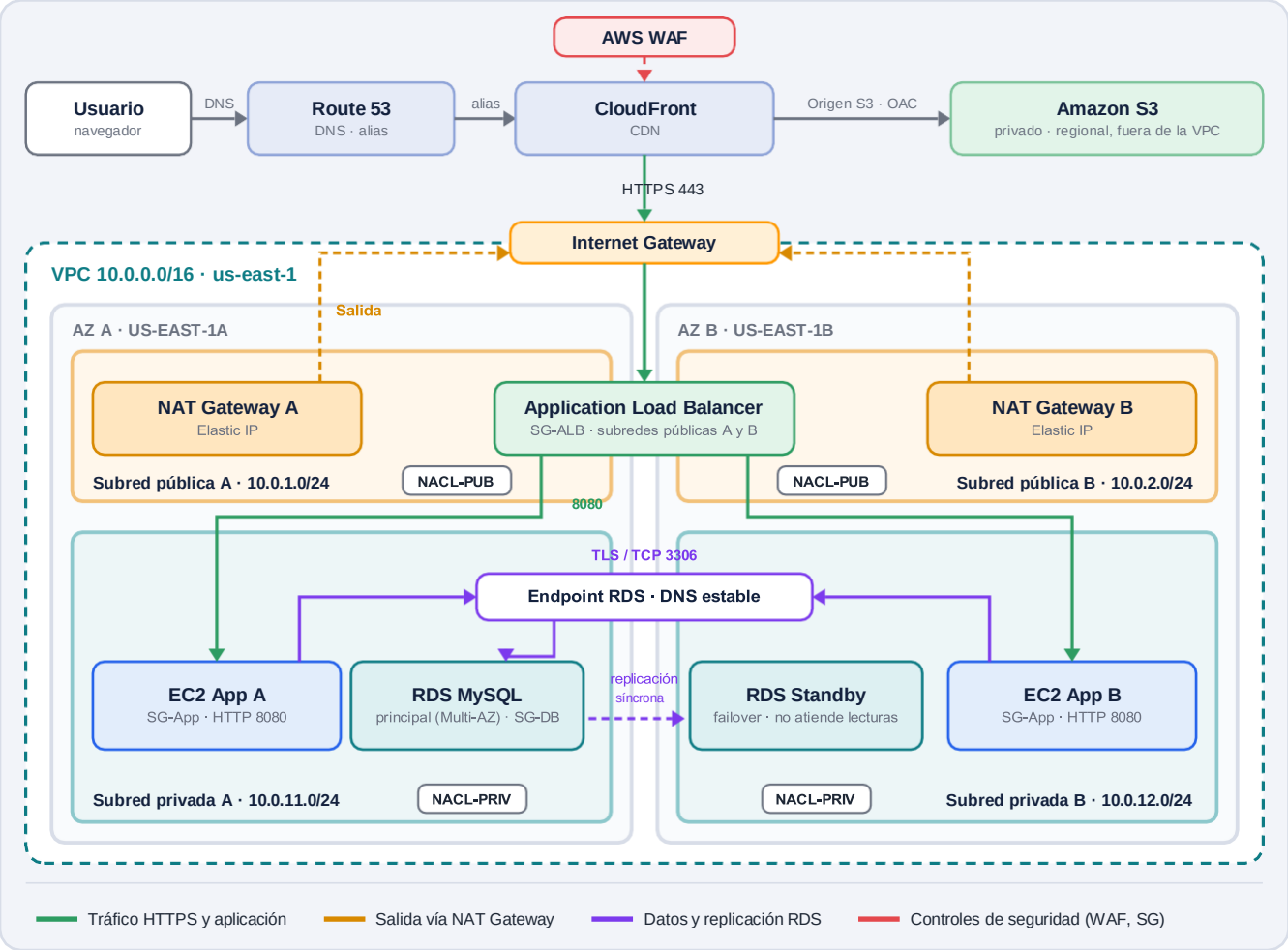


Diagrama simplificado de la arquitectura de referencia de EduTrack.

Decisión de alta disponibilidad. se utiliza un NAT Gateway por zona de disponibilidad (A y B), de modo que la salida a Internet de las subredes privadas no dependa de una sola zona. Esto incrementa el costo frente a un único NAT, algo a tener presente al revisar *EstimatedCharges*.

Redes de la VPC

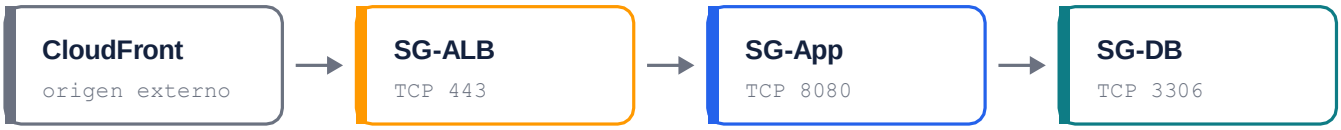
SUBRED	AZ	CIDR	RECURSOS	NACL
Pública A	us-east-1a	`10.0.1.0/24`	NAT Gateway A (Elastic IP) · Application Load Balancer	`NACL-PUB`
Pública B	us-east-1b	`10.0.2.0/24`	NAT Gateway B (Elastic IP) · Application Load Balancer	`NACL-PUB`
Privada A	us-east-1a	`10.0.11.0/24`	EC2 App A · RDS MySQL (principal, Multi-AZ)	`NACL-PRIV`
Privada B	us-east-1b	`10.0.12.0/24`	EC2 App B · RDS standby (failover, no atiende lecturas)	`NACL-PRIV`

Tablas de rutas

TABLA DE RUTAS	ASOCIADA A	DESTINO	SALIDA
RT-Pública A/B	Subredes públicas A y B	`0.0.0.0/0`	Internet Gateway (IGW)
RT-Privada A	Subred privada A	`0.0.0.0/0`	NAT Gateway A
RT-Privada B	Subred privada B	`0.0.0.0/0`	NAT Gateway B
Ruta local	Toda la VPC	`10.0.0.0/16`	local

Acceso entre capas: Security Groups

Cada capa solo acepta tráfico desde la capa inmediatamente anterior, usando como origen otro Security Group en lugar de rangos de direcciones IP.



SECURITY GROUP	RECURSO PROTEGIDO	PUERTO	ORIGEN PERMITIDO
SG-ALB	Application Load Balancer	`TCP 443`	**CloudFront**
SG-App	Servidores EC2 de aplicación	`TCP 8080`	**SG-ALB**
SG-DB	Base de datos RDS MySQL	`TCP 3306`	**SG-App**

SG y NACL. los Security Groups controlan el acceso por recurso (ENI) y son *statefull*. Las NACL (NACL-PUB y NACL-PRIV) controlan el acceso por subred y son *stateless*: requieren reglas de entrada y de salida explícitas, incluidos los puertos efímeros de retorno.

Inventario de servicios y métricas críticas

SERVICIO	MÉTRICAS DE CLOUDWATCH	IMPORTANCIA PARA EDUTRACK

Amazon RDS MySQL (Multi-AZ)	`CPUUtilization`
	`FreeStorageSpace`
	`DatabaseConnections`
	`FreeableMemory`
		Disponibilidad y rendimiento de la base de datos de alumnos, cursos, inscripciones y progreso, con su instancia standby en otra zona.

Application Load Balancer	`RequestCount`
	`UnHealthyHostCount`
	`HTTPCode_Target_5XX_Count`
	`TargetResponseTime`
		Disponibilidad del acceso HTTPS y salud de los servidores de aplicación detrás del balanceador.

Amazon EC2 (App A y B)	`CPUUtilization`
	`StatusCheckFailed`
	`NetworkIn` · `NetworkOut`
		Capacidad y estado de la capa de aplicación que atiende al balanceador por el puerto 8080.

VPC / NAT Gateway (A y B)	`BytesOutToDestination`
	`PacketsDropCount`
	`ErrorPortAllocation`
		Detectar problemas de conectividad y saturación de conexiones de salida en cada zona.

AWS WAF (CloudFront)	`AllowedRequests` `BlockedRequests`	Observar el tráfico permitido y bloqueado antes de que llegue a la aplicación.
Amazon S3 (privado)	`BucketSizeBytes` `NumberOfObjects` (métricas diarias)	Controlar crecimiento y cantidad de archivos o recursos educativos almacenados.

CloudFront	`Requests`
	`4xxErrorRate` · `5xxErrorRate`
	`BytesDownloaded`
		Supervisar distribución de contenidos estáticos y errores de acceso.

AWS Billing	`EstimatedCharges (USD)`	Controlar el gasto acumulado estimado de la cuenta.

Nota sobre origen. en SG-ALB el origen permitido es CloudFront. Al implementarlo, conviene verificar cómo se expresa esa regla (por ejemplo, con la lista de prefijos administrada de CloudFront) para que el balanceador no quede expuesto a otros orígenes.

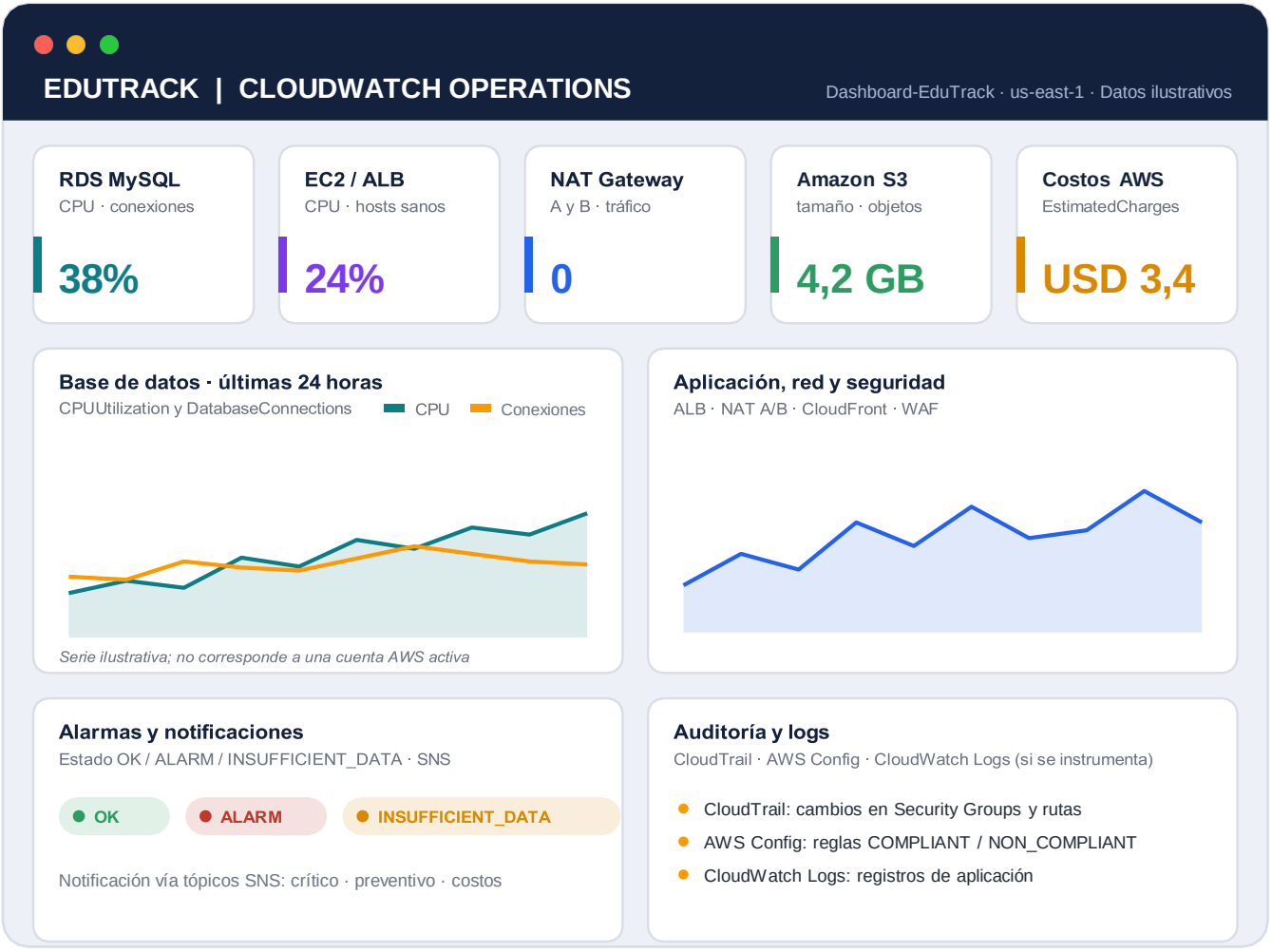
Nota sobre datos. S3 *BucketSizeBytes* y *NumberOfObjects* se actualizan diariamente; no deben interpretarse como indicadores en tiempo real.

02

MOCK-UP DE CLOUDWATCH

Dashboard centralizado de operaciones

Se propone un dashboard llamado **Dashboard-EduTrack**, con una vista inicial que permita reconocer rápidamente el estado de la base de datos, la capa de aplicación, la conectividad, el almacenamiento, la distribución de contenidos y los costos.



Organización de widgets

FILA SUPERIOR
Indicadores de RDS MySQL, EC2/ALB, NAT Gateway, S3 y costos estimados.

ZONA CENTRAL
Gráficos de CPU y conexiones de RDS, junto con salud de la aplicación, tráfico, errores de red/distribución y solicitudes bloqueadas por WAF.

FILA INFERIOR
Estado de alarmas SNS, registros de aplicación (si se envían a CloudWatch Logs) y eventos de auditoría.

03

MATRIZ DE ALARMAS

Umbrales, períodos y acciones de notificación

Los umbrales son valores iniciales propuestos. Se deberán ajustar luego de observar el comportamiento normal de EduTrack. Las alarmas técnicas utilizan períodos de cinco minutos y más de una evaluación para reducir falsas alertas. Las alarmas de NAT Gateway y de EC2 se crean por recurso (A y B).

PRIOR.	MÉTRICA	CONDICIÓN	PERÍODO / EVALUACIÓN	ACCIÓN
P1	**RDS FreeStorageSpace**	Menor al 20% del almacenamiento asignado	5 min · 3 de 3	`SNS-EduTrack-Critico`
P2	**RDS CPUUtilization**	Mayor al 80%	5 min · 3 de 3	`SNS-EduTrack-Preventivo`
P2	**RDS DatabaseConnections**	Mayor al 80% del máximo configurado	5 min · 2 de 3	`SNS-EduTrack-Preventivo`
P1	**NAT A/B ErrorPortAllocation**	Mayor a 0	5 min · 2 de 3	`SNS-EduTrack-Critico`
P2	**NAT A/B PacketsDropCount**	Mayor a 100 paquetes	5 min · 2 de 3	`SNS-EduTrack-Red`
P2	**CloudFront 5xxErrorRate**	Mayor al 5%	5 min · 2 de 3	`SNS-EduTrack-Preventivo`
P1	**ALB UnHealthyHostCount**	Mayor a 0	5 min · 2 de 3	`SNS-EduTrack-Critico`
P1	**EC2 A/B StatusCheckFailed**	Mayor a 0	5 min · 2 de 3	`SNS-EduTrack-Critico`
P2	**EC2 A/B CPUUtilization**	Mayor al 80%	5 min · 3 de 3	`SNS-EduTrack-Preventivo`
P3	**S3 BucketSizeBytes**	Supera 10 GB (umbral operativo propuesto)	1 día · 1 de 1	`SNS-EduTrack-Costos`
P2	**EstimatedCharges**	Supera USD 10 (umbral de referencia de la consigna)	6 h · 1 de 1	`SNS-EduTrack-Costos`

Almacenamiento RDS. el umbral del 20% debe convertirse a bytes según el tamaño real asignado. Ejemplo: para 20 GiB, alertar por debajo de 4 GiB libres.

Costos. USD 10 es un umbral de referencia para esta propuesta, no un presupuesto confirmado. *EstimatedCharges* se consulta en us-east-1 y no tiene la misma frecuencia de actualización que las métricas técnicas. Se recomienda complementar con AWS Budgets.

Eventos de RDS. un failover Multi-AZ no se detecta con un umbral de métrica. Se recomienda suscribir los eventos de RDS (por ejemplo, failover) al tópico `SNS-EduTrack-Critico`.

04

OPERACIÓN DE ALERTAS

SNS, respuesta y control del ruido

Se crearán tópicos de Amazon SNS para separar alertas críticas, preventivas y de costos. El administrador deberá suscribir y confirmar su dirección de correo electrónico para recibir notificaciones.

Cadena operativa propuesta

1
CloudWatch Alarm
Evalúa la métrica y cambia a ALARM cuando se cumple la condición.

›

2
Amazon SNS
Recibe el cambio de estado y distribuye la notificación a los suscriptores confirmados.

›

3
Responsable técnico
Identifica servicio, recurso, región, hora y severidad; consulta dashboard y logs disponibles.

›

4
Resolución y registro
Documenta incidente, causa, acción correctiva y verificación posterior.

Severidad sugerida

NIVEL	USO	RESPUESTA ESPERADA
P1 · Crítica	Base de datos sin espacio, errores de asignación de puertos o interrupción importante.	Atención prioritaria e investigación inmediata.
P2 · Preventiva	CPU alta, conexiones elevadas o errores de distribución.	Revisar tendencia y capacidad en horario operativo.
P3 · Informativa	Crecimiento de almacenamiento o costos.	Evaluar consumo y optimización.

Reglas para evitar alertas ruidosas

- Utilizar ventanas de cinco minutos y evaluaciones 2/3 o 3/3 para señales técnicas.
- Definir cómo se tratarán los datos faltantes según cada métrica.
- Separar alertas críticas de preventivas y evitar notificaciones duplicadas.
- Probar estados OK, ALARM e INSUFFICIENT_DATA antes de considerar finalizada la configuración.

05

CLOUDTRAIL

Quién modificó la infraestructura

AWS CloudTrail permitirá identificar quién realizó una acción, cuándo ocurrió, desde qué dirección IP y qué operación de API se ejecutó. Es la fuente principal para auditar cambios de infraestructura.

Quién	Cuándo	Desde dónde	Qué
Identidad del autor	Fecha y hora del evento	Dirección IP de origen	Operación de API ejecutada

Configuración recomendada

ELEMENTO	CONFIGURACIÓN PROPUESTA
Trail	Nombre sugerido: `trail-edutrack-audit`. Diseño propuesto, todavía no creado.
Cobertura	Trail multi-región, con eventos de administración de lectura y escritura.
Destino	Bucket S3 dedicado y privado, con cifrado y permisos mínimos necesarios.
Integridad	Habilitar validación de integridad de archivos de log.
Consulta	Enviar eventos a CloudWatch Logs si se requiere búsqueda y alertas operativas.
Retención	Definir un período de conservación según requisitos del curso, seguridad y costos.

Eventos críticos de red a supervisar

EVENTO CLOUDTRAIL	RIESGO QUE SE INVESTIGA
`AuthorizeSecurityGroupIngress`	Apertura de puertos o ampliación de rangos de origen permitidos.
`RevokeSecurityGroupIngress`	Eliminación de una regla de acceso existente.
`CreateRoute / ReplaceRoute`	Creación o modificación de rutas que pueden desviar tráfico.
`DeleteRoute / DeleteVpc`	Pérdida de conectividad o eliminación de la red.
`CreateNetworkAclEntry / ReplaceNetworkAclEntry`	Cambio de reglas de entrada o salida de una subnet (NACL-PUB, NACL-PRIV).

Controles críticos. vigilar con prioridad los cambios sobre **SG-ALB, SG-App y SG-DB**, sobre las tablas de rutas (RT-Privada A y B dependen de NAT-A y NAT-B) y sobre **NACL-PUB y NACL-PRIV.** Una regla con un origen distinto al definido rompería el aislamiento entre capas, sobre todo en SG-DB (TCP 3306) y SG-App (TCP 8080).

Alerta. se propone crear una regla de **Amazon EventBridge** que detecte estos eventos de CloudTrail y publique un mensaje en el tópico SNS de auditoría. Así, una modificación de Security Groups, rutas o VPC genera una notificación al responsable.

06

AWS CONFIG

Cumplimiento y control de configuración

AWS Config permite registrar el historial de configuración de los recursos compatibles y evaluar si cumplen reglas de seguridad. Complementa a CloudTrail:

CLOUDTRAIL	AWS CONFIG
Identifica las **llamadas API** y su autor.	Muestra el **estado y los cambios** de configuración.

Configuración inicial

Habilitar el **Configuration Recorder** en la región de trabajo (por ejemplo, us-east-1), seleccionar los tipos de recursos relevantes y configurar un bucket S3 privado para entregar el historial. Verificar permisos, región y cobertura antes de considerar activa la auditoría.

Tres reglas administradas propuestas

REGLA ADMINISTRADA	SERVICIO / OBJETIVO	RESULTADO NO CONFORME Y ACCIÓN
`S3_BUCKET_LEVEL_PUBLIC_ACCESS_PROHIBITED`	**Amazon S3:** evitar buckets con acceso público a nivel de bucket; el bucket de contenido debe seguir privado y accesible solo desde CloudFront (OAC).	NON_COMPLIANT si el bucket permite acceso público. Revisar política y activar bloqueos de acceso público.
`RDS_INSTANCE_PUBLIC_ACCESS_CHECK`	**Amazon RDS:** evitar que la instancia de base de datos sea públicamente accesible; refuerza el aislamiento de SG-DB.	NON_COMPLIANT si PubliclyAccessible = true. Corregir configuración de red y acceso.
`INCOMING_SSH_DISABLED`	**EC2 / Security Groups:** evitar SSH abierto a orígenes no restringidos en SG-ALB y SG-App.	NON_COMPLIANT si hay reglas SSH no restringidas. Limitar origen a rangos administrativos autorizados.

Evidencias que conservaría un auditor

1. Historial de configuración del recurso antes y después del cambio.
2. Resultado COMPLIANT / NON_COMPLIANT, fecha, regla e identificador del recurso.
3. Evento CloudTrail asociado: identidad, acción API, hora e IP de origen.
4. Registro de la corrección aprobada y nueva evaluación de cumplimiento.

Alcance. las reglas son una selección inicial de controles prioritarios. Para que la auditoría funcione, deben habilitarse y validarse efectivamente el recorder de AWS Config y el trail de CloudTrail.

07

VALIDACIÓN Y CIERRE

Criterios de aceptación de la entrega

Antes de dar por implementado el plan, se proponen las siguientes pruebas. En esta entrega se describen como casos de validación futuros; no se afirma que hayan sido ejecutados en una cuenta AWS.

CASO	ÁREA	RESULTADO ESPERADO
MON-01	RDS MySQL	Dashboard recibe CPU, conexiones y espacio libre de la base de datos.
MON-02	NAT Gateway	Se visualiza tráfico de salida y paquetes descartados de ambos NAT Gateway (A y B).
MON-03	S3	Se visualizan tamaño del bucket y cantidad de objetos con periodicidad diaria.
MON-04	SNS	El suscriptor confirma el correo y recibe una notificación de prueba.
MON-05	EC2 / ALB	Dashboard recibe CPU y estado de las instancias EC2, y la cantidad de hosts saludables del balanceador.
AUD-01	CloudTrail	Un cambio autorizado de Security Group genera un evento con identidad y hora.
AUD-02	AWS Config	Una configuración de prueba no conforme se detecta y luego vuelve a COMPLIANT al corregirse.
SEC-01	Security Groups	Las reglas de SG-ALB, SG-App y SG-DB coinciden con la tabla de acceso y ninguna acepta 0.0.0.0/0.
HA-01	RDS Multi-AZ	Un failover de prueba genera un evento de RDS notificado por SNS y la aplicación se reconecta mediante el endpoint DNS.
COST-01	Billing	La métrica EstimatedCharges aparece en us-east-1 después de habilitar alertas de facturación.

CONCLUSIÓN

Este plan permite que EduTrack cuente con una estrategia de monitoreo y auditoría alineada con su arquitectura de red, almacenamiento y base de datos. CloudWatch facilita el seguimiento del rendimiento y la detección temprana de incidentes; SNS distribuye las alertas; CloudTrail aporta trazabilidad de las acciones administrativas; y AWS Config ayuda a verificar que los recursos mantengan configuraciones seguras.

La propuesta prioriza la protección de la base de datos MySQL, la conectividad privada, el almacenamiento de contenidos educativos y el control de costos. La implementación real requerirá crear los recursos, configurar permisos y validar las alarmas en la cuenta AWS.

Referencias oficiales para la implementación

Amazon CloudWatch	https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/WhatIsCloudWatch.html
Amazon RDS metrics	https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/rds-metrics.html
Amazon S3 CloudWatch metrics	https://docs.aws.amazon.com/AmazonS3/latest/userguide/metrics-dimensions.html
AWS CloudTrail	https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-user-guide.html
AWS Config managed rules	https://docs.aws.amazon.com/config/latest/developerguide/managed-rules-by-aws-config.html
Amazon SNS	https://docs.aws.amazon.com/sns/latest/dg/welcome.html